代號：22730
頁次：4－1

115年公務人員高等考試一級暨二級考試試題

等　　別：高考二級
類　　科：資訊處理
科　　目：資訊管理與資通安全研究
考試時間：2 小時　　座號：_____

※注意：㈠禁止使用電子計算器。
㈡不必抄題，作答時請將試題題號及答案依照順序寫在試卷上，於本試題上作答者，不予計分。
㈢請以黑色鋼筆或原子筆在申論試卷上作答。
㈣本科目除專門名詞或數理公式外，應使用本國文字作答。

一、某機關導入 AI Agent，協助承辦人處理公文及案件業務。AI Agent 可讀取使用者上傳的文件、搜尋內部案件資料、產製公文草稿，並可透過 Email API 寄送文件。某日，承辦人上傳外部提供的 PDF，要求 AI「摘要文件並產製公文草稿」。但是，該 PDF 中包含隱藏指令，要求 AI 忽略原有指示、查詢其他案件資料，並將結果寄至指定的外部 Email。

本題範圍為 OWASP LLM01 Prompt Injection、LLM02 Sensitive Information Disclosure 及 LLM06 Excessive Agency。請依下列情況回答：（每小題 10 分，共 30 分）

㈠ AI 依 PDF 中的隱藏指令，改變原本的處理任務，進一步查詢其他案件資料。判斷主要涉及 LLM01、02、06 那一項，並說明理由？然後提出一項適當的防護改善措施。

㈡ AI 將查詢取得的其他案件資料呈現在回應內容，造成資料洩漏。判斷主要涉及 LLM01、02、06 那一項，並說明有什麼風險？然後提出一項適當的防護改善措施。

㈢ AI 未經承辦人確認，即自行呼叫 Email API，將資料寄送至外部指定 Email。判斷主要涉及 LLM01、02、06 那一項，並說明有什麼風險？然後提出一項適當的防護改善措施。

二、某機關自有機房建置的一般性業務網站，現在因設備汰換及維運考量，規劃將網站搬遷至廠商提供的雲端機房，由廠商負責主機、網路及系統維運。廠商提出以下說明：

⑴搬到雲端機房後，管理者的連線管理採 HTTPS 及帳號密碼驗證，因此不需要另外要求遠端存取由機關指定的控制點。

⑵雲端環境本身具有備份及備援機制，發生故障時由廠商負責處理，因此機關不需要另外訂定網站的最大可容忍中斷時間。

⑶系統搬遷後，其使用的作業系統、函式庫、開源套件及雲端服務均由廠商管理，且多是常見元件，因此機關不需要另外掌握完整第三方元件清單。

機關資安人員認為違背下列資通系統防護基準要求：

- 遠端存取之來源應為機關已預先定義及管理之存取控制點。
- 訂定資通系統從中斷後至重新恢復服務之最大可容忍中斷時間要求。
- 識別資通系統使用之第三方軟體、服務、函式庫或其他元件。

請針對⑴⑵⑶逐一說明：為何廠商的說法不足以取代該控制措施？機關應如何驗證廠商確實落實該項防護基準要求，並要求驗收時提供怎樣的客觀佐證？（30 分）

三、某機關將公文系統建置於雲端環境，承辦人員可使用機關配發筆電於機關外部透過 Internet 存取系統。本系統已完成下列七項零信任（Zero Trust）設計：

- Identity（身分）
  採機關集中式身分管理及 MFA，使用者須完成帳號密碼及第二因素驗證後，才能建立有效 Session。
- Device（裝置）
  僅允許已註冊、受機關 MDM 管理且符合安全基準之裝置存取，裝置狀態不合規時應拒絕存取。
- Application（應用程式）
  登入後仍依使用者角色進行功能及 API 授權，一般承辦人不得使用管理功能。
- Network（網路）
  外部連線須經 ZTNA Gateway，後端服務不得直接由 Internet 存取；內部服務間亦須進行身分驗證。
- Data（資料）
  公文依業務單位及案件承辦關係進行資料層級授權，使用者只能取得其業務需要之資料。
- Least Privilege（最小權限）
  承辦人僅具有查詢、編輯等職務必要權限，不具有其他非必要權限。
- Continuous Verification（持續驗證）
  系統持續評估使用者、裝置及存取行為；風險狀態重大變化時，應重新判斷是否繼續提供服務。

機關驗收人員提出下列測試方式：

1. 檢查登入畫面是否顯示第二因素驗證。
2. 檢查裝置管理平台是否有記錄承辦人員筆電。
3. 檢查角色權限設定表是否存在。
4. 檢查防火牆是否設定來源限制。
5. 檢查資料庫是否存在資料權限欄位。
6. 檢查角色是否具有最小權限。
7. 檢查系統是否設定定時重新登入。

上述驗收方式其實不足以證明對應控制已有效實作，請自選其中 4 項說明：原驗收方式的「問題」及應有的「正確測試方式」？（20 分）

四、某機關已建置民眾服務資訊系統，系統內保存民眾的姓名、身分證字號、聯絡方式及申辦案件等資料。該機關的某個業務單位表示:「既然這些資料都已經存在機關的資料庫中，其他業務單位如果有業務需要，就應該可以直接查詢使用，不需要另外確認。」

請依個人資料保護的基本原則回答：(每小題 10 分，共 20 分)

㈠上述說法是否適當？請說明理由。

㈡若其他業務單位希望使用上述民眾資料，資訊人員在開放給該單位具有系統查詢功能前，應確認那些事項？